SHODAN.IO

The Search Engine for the Internet of Things

TryHackMe Room — Cyber Security Group Presentation

What we'll cover:

- What is Shodan?
- How to use Filters & Dorks
- Shodan Monitor & Extensions
- The Shodan API

🔍 WHAT IS SHODAN?

Think of it like this...

Google searches WEBSITES.
Shodan searches DEVICES.

Shodan scans the entire internet and records what services are running on every device — then lets you search them.

☕ **Is your coffee machine on the internet?**

📷
CCTV Cameras

Publicly accessible cameras worldwide

🌐
Web Servers

Apache, Nginx, IIS servers globally

🔒
Databases

Open MySQL, MongoDB, Redis instances

🏭
ICS/SCADA

Industrial control systems exposed online

Used by: Security researchers · Penetration testers · Bug bounty hunters · Companies checking their own exposure

⚙ HOW SHODAN WORKS — BANNERS

1

Shodan constantly scans all public IP addresses across the internet

2

It connects to open ports (80, 443, 22, 3306, etc.) on every device

3

The device responds with a 'banner' — info about what's running

4

Shodan stores & indexes the banner, making it searchable by anyone

Example Banner (what Shodan actually stores):


```
{
  "data": "Moxa Nport Device",   "Status": "Authentication disabled",
  "ip_str": "46.252.132.235",   "port": 4800,   "org": "Starhub Mobile",
  "location": { "country_code": "SG" }
}
```

🔎 SEARCHING WITH FILTERS

Shodan's power comes from its search filters. You can narrow results by port, location, product, vulnerability and more.

`asn:AS14061`

Search all IPs belonging to a specific company (DigitalOcean here)

`product:MySQL`

Find devices running a specific service or product

`port:22`

Find all devices with a specific port open

`country:ZA`

Limit results to a specific country (ZA = South Africa)

`os:"Windows 10"`

Filter by operating system

`vuln:ms17-010`

Find IPs vulnerable to EternalBlue (premium only)

💡 Combine filters! e.g. `asn:AS14061 product:MySQL` — finds MySQL servers in DigitalOcean's network

AUTONOMOUS SYSTEM NUMBERS (ASN)

An ASN is a unique number that identifies a large organisation's block of IP addresses. Think of it as a postcode for a company's internet space.

Step 1

`ping tryhackme.com`

Get the IP address from the ping response

Step 2

`asnlookup.com`

Paste the IP → find the ASN (e.g. AS14061 = DigitalOcean)

Step 3

`asn:AS14061`

Search Shodan with the ASN filter to find all their services

✅ Why? Big companies own their own ASN — you can map all their internet-facing services in one search!

🎯 SHODAN DORKING

'Dorks' are pre-built search queries that find interesting/vulnerable devices. Here are some powerful examples:

💀 Ransomware Detection

```
has_screenshot:true encrypted attention
```

Uses OCR on screenshots to find machines taken over by ransomware — a genuinely shocking result!

🏭 Industrial Control Systems

```
screenshot.label:ics
```

Finds ICS/SCADA systems — critical infrastructure like power plants and water facilities

❤️‍🩹 Heartbleed Vulnerability

```
vuln:CVE-2014-0160
```

Finds machines still vulnerable to the famous OpenSSL bug (business/academic accounts only)

☀️ SolarWinds via Favicon

```
http.favicon.hash:-1776962843
```

Tracks the SolarWinds supply chain attack by searching for a specific favicon hash

SHODAN MONITOR

What is it?

Shodan Monitor lets you watch your own network 24/7. Enter your IP range and Shodan continuously scans it — alerting you when it finds problems.

monitor.shodan.io/dashboard

Tip: Bug bounty hunters use this to monitor OTHER companies' networks and get notified of new vulnerabilities automatically!

Note: Premium product — watch for Black Friday $1 deals!

Dashboard shows you:

Top Open Ports
Most commonly exposed services

Top Vulnerabilities
Security issues you must fix now

Notable Ports
Unusual ports you might not expect to be open

Potential Vulnerabilities
Predicted security risks

Notable IPs
Specific addresses that need investigation

🧩 EXTENSION & API

🧩 Browser Extension

Install the Shodan Chrome extension to instantly see info about any website you visit:

- IP address of the web server
- Open ports on that server
- Geographic location
- Known security vulnerabilities

🎯 *Great for bug bounty hunters — instantly triage if a target looks vulnerable!*

⚡ Shodan API

Developers can query Shodan programmatically. Use cases:

- Write scripts to monitor your company's IPs
- Automatically alert when new ports open
- Scan for vulnerabilities on schedule
- Build your own security dashboards

```
Requires a Shodan account to use
```

🔗 Chrome Extension: chrome.google.com/webstore → Search 'Shodan'
🔗 API Docs: developer.shodan.io

⚖ ETHICS & LEGAL USE

✅ DO

- ✔ Use Shodan to audit YOUR OWN network
- ✔ Pen test with explicit written permission
- ✔ View publicly accessible webcams (just observe)
- ✔ Research & learn from exposed services
- ✔ Use vuln filters to protect your org (business account)
- ✔ Report vulnerabilities responsibly

❌ DON'T

- ✗ Attack or exploit devices you found
- ✗ Try to break into password-protected systems
- ✗ Access private data even if 'publicly visible'
- ✗ Use Shodan to target individuals
- ✗ Scan networks without permission
- ✗ Ignore your country's computer crime laws!

SHODAN.IO

Key Takeaways

Search Engine for Devices

Shodan indexes internet-connected devices — cameras, servers, routers, industrial systems and more

Powerful Filters

Use filters like asn:, product:, port:, country: and vuln: to narrow searches

Dorking

Pre-built dork queries find specific targets like ransomware victims or vulnerable systems instantly

Shodan Monitor

Continuously watch your own network and get alerted when vulnerabilities are detected

Extension & API

Browser extension for quick recon; API for automated security scripts and monitoring

Use Responsibly

Always get permission before testing. Viewing ≠ attacking. Know your local cyber laws!